مستندات پروژه سایت رزومه‌ساز

۱. خلاصه پروژه

این پروژه یک **سایت رزومه‌ساز آنلاین** است که با فریم‌ورک جنگو (Django) پیاده‌سازی شده است. کاربران می‌توانند ثبت‌نام کنند، پروفایل شخصی بسازند، مهارت‌ها، پروژه‌ها و گواهی‌نامه‌های خود را اضافه کنند و در نهایت رزومه خود را به صورت PDF دانلود کنند.

آدرس سایت آنلاین: mohammad2000.pythonanywhere.com

مخزن گیت‌هاب: github.com/safaie983-pixel/Resume_Site_Students

۲. تکنولوژی‌های استفاده شده

- **Backend:** Python 3.13, Django 6.1.2
- **Database:** SQLite
- **Frontend:** HTML5, CSS3, JavaScript (طراحی ریسپانسیو و Glassmorphism)
- **خروجی PDF:** xhtml2pdf, ReportLab (با پشتیبانی کامل از فونت فارسی)

۳. قابلیت‌های اصلی

- سیستم احراز هویت (ثبت‌نام، ورود، خروج)
- پنل کاربری اختصاصی و پنل مدیریت (Jazzmin)
- مدیریت مهارت‌ها، تجربه‌های کاری، تحصیلات، پروژه‌ها و گواهی‌نامه‌ها
- آپلود عکس پروفایل و دانلود PDF رزومه
- جستجوی پیشرفته در بین کاربران
- پشتیبانی از حالت تاریک و روشن (Dark/Light Mode)

۴. مستندات امنیتی (پوشش کامل OWASP Top 10)

امنیت پروژه بر اساس استانداردهای OWASP Top 10 (2021) و OWASP WSTG پیاده‌سازی شده است.

کد	آسیب‌پذیری	وضعیت	اقدام انجام شده
A01	کنترل دسترسی (Broken Access Control)	پوشش داده شد	استفاده از @login_required و بررسی مالکیت آیتم‌ها در زمان حذف
A02	شکست رمزنگاری (Cryptographic Failures)	پوشش داده شد	انتقال SECRET_KEY به .env، استفاده از کوکی‌های Secure و HttpOnly
A03	تزریق (Injection)	پوشش داده شد	استفاده کامل از Django ORM، جلوگیری از SQL خام و Escape خودکار
A04	طراحی ناامن (Insecure Design)	پوشش داده شد	محدودیت حجم آپلود (5MB) و Rate Limiting
A05	پیکربندی نادرست (Security Misconfiguration)	پوشش داده شد	هدرهای امنیتی (CSP, X-Frame)، صفحات خطای سفارشی، تنظیم DEBUG=False
A06	اجزای آسیب‌پذیر (Vulnerable Components)	پوشش داده شد	استفاده از آخرین نسخه Django و به‌روزرسانی منظم پکیج‌ها
A07	شکست احراز هویت (Auth Failures)	پوشش داده شد	اعتبارسنجی قوی رمز عبور و جلوگیری از Brute-Force با django-axes
A08	یکپارچگی داده (Integrity Failures)	پوشش داده شد	استفاده از فرم‌های امن Django و ثبت تغییرات با Audit Log
A09	لاگ و مانیتورینگ (Logging Failures)	پوشش داده شد	ثبت تمام تغییرات ادمین و تلاش‌های ناموفق ورود
A10	جعل درخواست (SSRF)	پوشش داده شد	اعتبارسنجی فیلدهای URL و جلوگیری از دریافت آدرس‌های ناامن

۵. استقرار (Deployment)

پروژه در محیط هاست ابری رایگان **PythonAnywhere** مستقر شده است. مراحل استقرار شامل ساخت محیط مجازی (Virtualenv)، نصب پکیج‌های requirements.txt، تنظیم فایل WSGI، جمع‌آوری فایل‌های استاتیک (collectstatic) و تنظیم مسیرهای مدیا بوده است.